

Northside Home Goods

Incident Response Plan (IRP)

Version: 1.0 | **Scope:** Security Events and Data Breaches

1. Purpose

This Incident Response Plan establishes a standardized, repeatable process for Northside Home Goods to detect, contain, and recover from cybersecurity incidents. The goal is to minimize business interruption to our retail and e-commerce operations, prevent the destruction of forensic evidence, and ensure compliance with cyber insurance notification requirements.

2. Incident Response Team & Roles

- **Operations Manager:** Serves as the Incident Commander. Responsible for coordinating the business response, approving communications, and acting as the primary liaison to the cyber insurance broker.
- **IT Lead (Internal/Outsourced):** Leads technical containment, forensic evidence preservation, system restoration, and technical vendor coordination.
- **HR Liaison:** Manages internal employee communications and coordination if employee data is compromised.

3. Escalation and Cyber Insurance Notification

Time is critical during a breach.

1. **Internal Escalation:** Any employee who suspects a security incident (e.g., a ransomware screen, unusual payment routing, or a compromised email) must immediately disconnect the affected machine from the network (unplug the ethernet cable or disable Wi-Fi) but **DO NOT turn the machine off**, as this destroys forensic memory. Contact the IT Lead immediately.
2. **Insurer Notification:** If a material breach, ransomware event, or Business Email Compromise (BEC) is confirmed, the Operations Manager must notify the cyber insurance provider **within 24 hours**.
 - *Warning:* Do not engage external forensic firms, legal counsel, or ransomware negotiators without explicit written approval from the cyber insurance claims adjuster. Doing so may void coverage.

4. Incident Phases

Phase I: Preparation & Detection

- Maintain updated offline backups and a hardcopy of this IRP.
- Monitor anti-virus/EDR alerts, unusual after-hours logins, and customer reports of fraudulent charges or strange emails.

Phase II: Containment

- **Short-Term Containment:** Isolate compromised endpoints from the network. Disable compromised user accounts in Active Directory or M365 immediately. Revoke active session tokens.
- **Long-Term Containment:** Rebuild compromised machines from clean baseline images. Force a global password reset for all administrative and affected user accounts. Apply missing security patches that enabled the initial vector.

Phase III: Eradication & Recovery

- Verify that all malicious payloads, unauthorized inbox forwarding rules, and backdoor accounts have been removed.
- Restore business data from the most recent verified clean backup. **Never restore data directly over the compromised drive;** restore to a clean environment.
- Gradually bring retail POS systems and e-commerce portals back online in a prioritized sequence, monitoring closely for reinfection.

Phase IV: Post-Incident Review

- Within two weeks of the incident's resolution, the Incident Response Team must hold a "Lessons Learned" meeting.
- Document the root cause of the incident, evaluate the effectiveness of the response, and assign corrective actions (e.g., purchasing new security tools, updating training, or rewriting policies) to prevent a recurrence.